

HiveForce Labs

THREAT ADVISORY

VULNERABILITY REPORT

**Several vulnerabilities are addressed by
Fortinet across its product range**

Date of Publication

January 5, 2023

Admiralty Code

A1

TA Number

TA2023005

Summary

First Seen: January 3, 2023

Affected Products: FortiADC, FortiManager, FortiPortal, FortiTester, and FortiWeb.

Impact: Execution of OS commands and drive-by-download attacks.

CVE

CVE	NAME	PATCH
CVE-2022-39947	Command injection in FortiADC	
CVE-2022-45857	Incorrect user management in FortiManager	
CVE-2022-41336	XSS in FortiPortal	
CVE-2022-35845	Multiple command injection vulnerabilities in FortiTester	
Unassigned	Header injection in FortiWeb API	

Vulnerability Details

#1

Fortinet addressed security vulnerabilities across its products, most notably FortiADC, which has a high-severity command injection bug listed as CVE-2022-39947 due to incorrect input validation in the web GUI. A remotely authenticated user can send a specially crafted HTTP request to the software, allowing them to execute arbitrary OS commands on the victim system.

#2

An improper user management vulnerability (CVE-2022-45857) in the FortiManager VDOM creation component potentially allows an attacker to access a FortiGate without a password via newly formed VDOMs when the super admin profiled admin account is deactivated. XSS was discovered on policy column settings in FortiPortal, as well as multiple command injection vulnerabilities in FortiTester's GUI and API.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-39947	FortiADC version: 7.0.2 - 5.4.0	cpe:2.3:a:fortinet:fortiadc:-:*:*:*:*:*	CWE-78
CVE-2022-45857	FortiManager version: 6.2.0 - 7.0.1	cpe:2.3:a:fortinet:fortimanager:-:*:*:*:*:*	CWE-286
CVE-2022-41336	FortiPortal version: 5.0.0 - 6.0.11	cpe:2.3:a:fortinet:fortiportal:-:*:*:*:*:*	CWE-79
CVE-2022-35845	FortiTester version: 2.6.0 - 7.1.0	cpe:2.3:a:fortinet:fortitester:-:*:*:*:*:*	CWE-78
Unassigned	FortiWeb version : 7.0.2 - 6.3.6	cpe:2.3:a:fortinet:fortiweb:-:*:*:*:*:*	CWE-113

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5’s Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the ‘Potential MITRE ATT&CK TTPs’ & ‘Patch Details’ on the following pages.

Potential **MITRE ATT&CK** TTPs

TA0042 Resource Development	TA0001 Initial Access	TA0002 Execution	TA0003 Persistence
TA0008 Lateral Movement	T1588 Obtain Capabilities	T1588.006 Vulnerabilities	T1543 Create or Modify System Process
T1210 Exploitation of Remote Services	T1190 Exploit Public-Facing Application	T1078 Valid Accounts	T1098 Account Manipulation

Patch Links

<https://www.fortiguard.com/psirt/FG-IR-22-061>

<https://www.fortiguard.com/psirt/FG-IR-22-371>

<https://www.fortiguard.com/psirt/FG-IR-22-313>

<https://www.fortiguard.com/psirt/FG-IR-22-274>

<https://www.fortiguard.com/psirt/FG-IR-22-250>

References

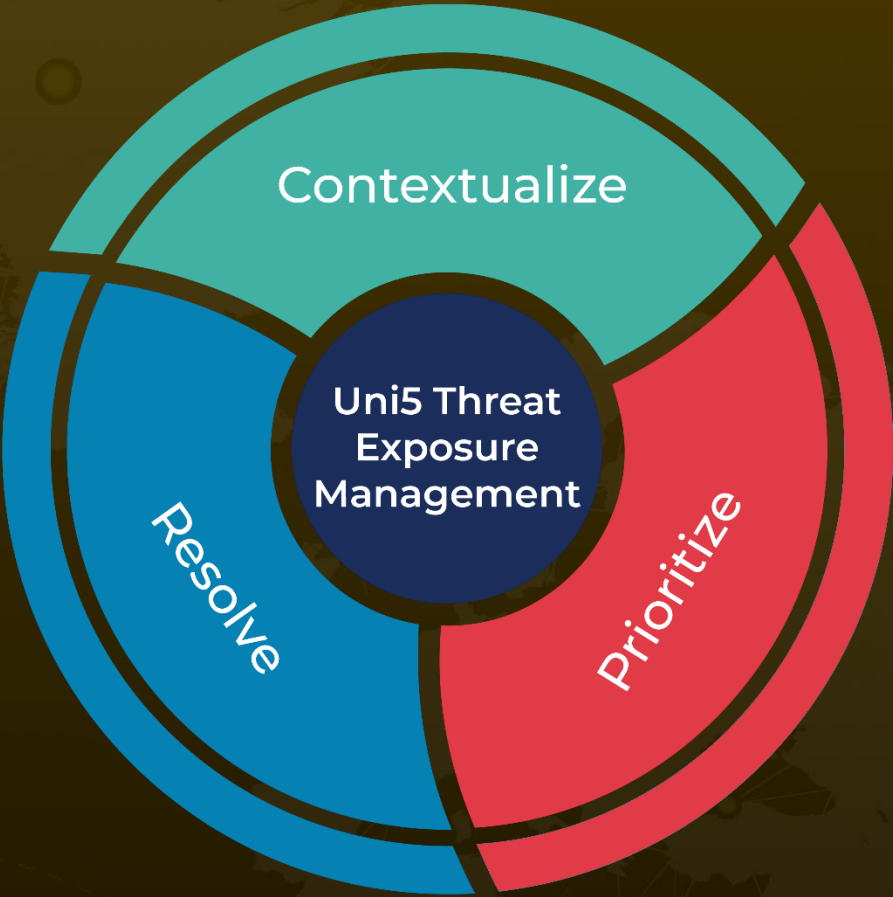
<https://www.fortiguard.com/psirt?date=01-2023>

https://www.securityweek.com/high-severity-command-injection-flaws-found-fortinets-fortitester-fortiadc?&web_view=true

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
January 5, 2023 • 2:22 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com